

Trusted AI Safety Expert: Module 7

Official Study Guide



Version Number: 20251015

© 2025 Cloud Security Alliance – All Rights Reserved. You may download, store, display on your computer, view, print, and link to the Cloud Security Alliance at <https://cloudsecurityalliance.org> subject to the following: (a) the draft may be used solely for your personal, informational, noncommercial use; (b) the draft may not be modified or altered in any way; (c) the draft may not be redistributed; and (d) the trademark, copyright or other notices may not be removed. You may quote portions of the draft as permitted by the Fair Use provisions of the United States Copyright Act, provided that you attribute the portions to the Cloud Security Alliance.

Acknowledgments

Lead Authors

Tugce Guler
Satwik Kamarthi
Wei Li
Charlie Meyer
Nihar Sanda
Sam Scarpino
James Sheldon
Thulasi Tholeti
Peter Vickers

Contributors

Cansu Canca
Shiran Dudy
Laura Haaber Ihle
Shantanu Jain
Tomo Lazovich
Resmi Ramachandranpillai
Annika Schoene

CSA and NU Global Staff

Marina Bregkou
Josh Buker
Daniele Catteddu
Holly Franklin
Ryan Gifford
Keagan Goodhue
Tara Hanson
Larry Hughes
Nicholas Knopf
Stephen Lumpe
NJ Park
Hannah Rock
Anna Schorr
Stephen Smith
Cathy Jo Swain
Kevin Tobin
Jamie Traynor
Kira Twombly

Table of Contents

- Acknowledgments..... 3
 - Lead Authors..... 3
 - Contributors..... 3
 - CSA and NU Global Staff..... 3
- Table of Contents..... 4
- Introduction to TAISE..... 5
 - Receive a Respected Industry Credential..... 5
 - Acquire In-Demand Skills..... 5
 - Go Beyond Theory..... 5
- Module 7: Introduction to AI Security & Safety..... 6**
 - Learning Objectives..... 6
 - 7.2 Module Vocabulary..... 7
 - 7.3 An Analytic Framework for Safety and Security..... 9
 - 7.4 Distinguishing AI Safety and Security..... 14
 - 7.5 Key Security Challenges in AI Systems..... 19
 - 7.6 AI-Augmented Cyber Security Testing and Red Teaming..... 23
 - 7.7 AI Tools for Zero Trust Implementation..... 28
 - 7.8 Challenges in Securing Generative and Agentic AI Systems..... 32
 - 7.9 Case Study #1: LLMs for Automated Phishing Scams..... 35
 - 7.10 Case Study #2: Secure Data Flow in Multinational Operations..... 37
 - 7.11 Summary..... 38
- Change Log..... 40

Introduction to TAISE

If AI is going to shape the world, we need people who know how to shape it safely.

The **Trusted AI Safety Expert (TAISE)** certificate, created by the Cloud Security Alliance (CSA) and Northeastern University, is a rigorous, research-backed program for professionals who build, manage, or audit intelligent systems. Through 10 comprehensive modules and a final certificate exam, learners gain practical skills to evaluate and mitigate real-world AI risks, apply AI safety and security controls, navigate compliance frameworks, and lead responsible AI adoption across industries. TAISE is more than a certificate—it's a commitment to advancing safe, secure, and responsible AI.

Receive a Respected Industry Credential

TAISE is co-issued by CSA, **the global leader in cloud security standards**, and Northeastern University, **a top academic institution for AI ethics and experiential learning**. This joint recognition enhances your professional credibility, providing a globally respected credential to highlight on resumes, LinkedIn, and professional profiles.

Acquire In-Demand Skills

Professionals will learn to work with frameworks such as **NIST AI RMF, CSA AICM, ISO standards**, and **MITRE A TLAS** while mastering **threat classification, data privacy, model governance, and AI-specific incident response**. These capabilities directly map to the urgent needs of enterprises adopting AI.

Go Beyond Theory

The **TAISE Prompt Library** transforms concepts into hands-on practice. It offers curated prompts and exercises that show learners how to use large language models to reinforce and apply safety principles from each module. While not an exam prep tool, it helps professionals **translate training into job-ready skills**.



Module 7: Introduction to AI Security & Safety

As artificial intelligence becomes increasingly integrated into critical business operations and everyday life, understanding how to build, deploy, and maintain AI systems securely has never been more critical. This module explores the essential concepts of AI safety and security—two related but distinct disciplines that are fundamental to responsible AI deployment. You'll explore how traditional cyber security principles apply to AI systems while discovering the unique challenges that emerge when securing generative AI systems and autonomous agents.

Through real-world examples spanning from nuclear power plants to traffic management systems, you'll learn to distinguish between protecting AI systems from external threats (AI security) and ensuring AI systems don't cause unintended harm (AI safety). By the end of this module, you'll have a comprehensive understanding of the four pillars of AI security, practical experience with threat modeling frameworks, and insights into how AI is transforming cyber security practices through automated testing and threat detection.



Access the [TAISE Prompt Library](#), a free collection of curated prompts designed to complement the TAISE training. This optional resource provides example prompts and techniques that show how to use large language models (LLMs) to explore, reinforce, and apply key ideas from each module.

Learning Objectives

In this module, you will learn to:

- Define the distinctions between AI safety and AI security
- Explore the role of AI in enhancing cyber security and overall risk management
- Identify the common challenges in securing generative AI systems

7.2 Module Vocabulary

AI alignment keeps AI goals and behavior consistent with human values and intended outcomes. This includes preventing reward hacking, bias, and unintended side effects.

AI safety is the discipline of ensuring AI systems operate as intended without causing unintended harm. It focuses on robustness, fairness, and minimizing risks to people, property, or the environment.

AI security is the discipline of protecting AI systems from malicious attacks or misuse. It covers threats such as data poisoning, adversarial inputs, and model theft, and it ensures confidentiality, integrity, and availability.

Data drift is a phenomenon where the statistical distributions, patterns, or characteristics of data that an AI system encounters during operation gradually or suddenly shift away from the distribution of data used to train the model. This drift can occur naturally over time or be artificially induced by malicious actors, potentially compromising model performance, reliability, and security.

Data extraction is a type of AI security attack where adversaries attempt to infer or reconstruct sensitive information from an AI model's training data by strategically querying the deployed model. Through strategically crafted inputs and analysis of the model's outputs, attackers can potentially recover private, confidential, or proprietary information that was used to train the model.

Data poisoning is a type of AI security attack where adversaries deliberately inject malicious, corrupted, or misleading data into a model's training dataset with the intent to compromise the model's behavior, performance, or security. This attack targets the foundation of machine learning systems—the training data—to manipulate how the model learns and makes decisions.

A **digital twin** is a set of adaptive models that emulate the behavior of a physical system in a virtual system, getting real-time data to update itself along its life cycle. The digital twin replicates the physical system to predict failures and opportunities for changing, prescribe real-time actions for optimizing or mitigating unexpected events, and observe and evaluate the operating profile of the system.

A **model backdoor** is a type of AI security vulnerability where a hidden trigger or malicious functionality is embedded within a machine learning model. It then activates specific unintended behaviors when exposed to particular input patterns while maintaining normal performance on regular inputs. These backdoors can be inserted during training or fine-tuning or through supply chain compromise.

Enterprise infrastructure refers to all of the resources required to provide a service or product, including hardware, software, models, IT networks, data, security, and governance.

Enterprise architecture is a business function that aligns technology systems with business goals and provides a systematic way to describe and manage complexity.

Model extraction is a type of AI security attack where adversaries attempt to steal or replicate the functionality, architecture, and learned knowledge of a proprietary machine-learning model by systematically querying the target model and analyzing its responses. The goal is to create a functionally equivalent "surrogate" model without having access to the original training data, model parameters, or

architecture details.

Model inversion is a type of AI security attack where adversaries attempt to reconstruct or infer sensitive information about the training data by exploiting access to a trained model's parameters, gradients, or internal representations. Unlike model extraction, which steals functionality, model inversion specifically targets the recovery of private data that was used to train the model.

Privacy leakage is an AI security vulnerability where machine learning models inadvertently reveal sensitive, private, or confidential information about individuals or entities that were part of the training dataset. This occurs when models "memorize" specific details from their training data and later expose this information through their outputs, responses, or behavior patterns.

Zero Trust is a "never trust, always verify" security model where every access request, whether by users, models, or systems, must be continuously authenticated and authorized.

7.3 An Analytic Framework for Safety and Security

In Module 6, we saw that safety and security are core characteristics of AI system trustworthiness in the NIST AI Risk Management Framework. These concepts, however, did not emerge in isolation. The practices we now apply to AI are built on decades of research in the areas of safety and security for operational technology (OT) and information technology (IT). In this lesson, we will first define safety and security. Then, we will introduce an analytical framework that maps safety and security responsibilities across the different layers of an enterprise infrastructure. This framework will give us a structured way to think about risks, and it will serve as the foundation for analyzing safety and security in AI systems in the next lesson.

Defining Safety and Security

ISO/IEC TS 5723:2022 is a widely applied technical standard that gives organizations a common vocabulary about system trustworthiness (<https://www.iso.org/standard/81608.html>). According to this standard:

- **Safety** is “the property of a system such that it does not, under defined conditions, lead to a state in which human life, health, property, or the environment are endangered. It involves reducing both the probability of expected harm and the possibility of unexpected harm.”
- **Security** is the “resistance to intentional, unauthorized act(s) designed to cause harm or damage to a system.”



Safety focuses on reducing and mitigating harm, whether physical or cyber, that a system might cause during its intended operations. Security, on the other hand, is about protecting the system from attackers who seek to disrupt its operation or cause harm through deliberate attacks.

Although safety and security have distinct focuses, they are interdependent. A security breach can lead to safety hazards (e.g., compromised industrial control systems lead to unsafe operating conditions), while a safety failure can expose security vulnerabilities (e.g., predictable failure events that attackers can exploit). Because of these overlaps, organizations sometimes use the terms loosely or interchangeably. We recommend following the ISO’s definitions to avoid confusion, and we also recommend systematically analyzing risks from both categories.

Enterprise Architecture as an Analytical Framework

It is easy to come up with a list of safety and security concerns for a given system. But as systems grow larger and more complex, the list becomes harder to manage. In this case, a framework helps us assign responsibilities and ensure that nothing important falls through the cracks.

Most modern systems are a blend of operational technology (OT) and information technology (IT). Industries such as manufacturing, aviation, and energy are OT-heavy, relying on control systems to manage physical processes. Others, such as finance or healthcare analytics, are IT-heavy, depending more on data management, computation, and business workflows.

There are different ways to study these systems. In OT-heavy contexts, especially manufacturing, you may often hear about cyber-physical systems (CPS) or the Internet of Things (IoT). These concepts focus on how physical machinery is increasingly connected to digital networks and computation. But CPS and IoT are not separate from the larger picture: They serve business functions and interact with other business processes. In that sense, they are special cases within the broader discipline of enterprise architecture (EA).

Enterprise architecture takes a holistic view in aligning technology systems with business goals and provides a systematic way to describe and manage complexity. Most organizations don't start with a clear architecture. Instead, technology systems grow organically, with new applications and integrations added as needs arise. Over time, this creates a tangled landscape. To address this, EA helps organizations take stock of what they have and move toward intentional design. The same logic applies to safety and security: We can use the EA framework to describe and gradually shift into the intentional design of safety and security controls.

As a family of approaches, EA shares the same goal of intentionality. The idea dates back to the 1960s, with John Zachman formalizing early methods in the 1980s ([Reference](#)). Among the many frameworks developed since that time, The Open Group Architecture Framework (TOGAF) has become one of the most widely used ([Reference](#)). Real-world EA can be very detailed; for example, the Cloud Security Alliance's Trusted Cloud Initiative reference model spans dozens of components and relationships.

In this lesson, we'll adapt The Open Group Architecture Framework (TOGAF) as our analytical framework. This approach lets us systematically consider both safety and security responsibilities when deploying a technology for a specific business function. The same framework will also carry forward into the next lesson, when we analyze AI-specific safety and security risk and its controls.

An EA-Based Analytical Framework for Safety and Security

The document ISO/IEC TS 5723:2022 defines safety as a property of a system such that it does not cause harm under defined conditions, while security is the resistance of a system to intentional, unauthorized acts that could cause harm or damage. These properties are achieved and strengthened through the controls and practices that organizations put in place across their systems. The table below outlines representative controls and practices at different layers of an enterprise architecture.

The reference TOGAF usually consists of four high-level domains: business, data, applications, and technology. For this course, we adjust the scope to fit our focus on technical systems rather than business strategy, reducing the emphasis on high-level business architecture and instead breaking down the technology domain in more detail. The result is a six-layer framework:

- **Governance** covers strategic oversight such as policies, compliance, resource allocation, and accountability.
- **Operation** refers to the day-to-day execution of processes and the applications that support business functions.
- **Data and Information** focuses on how data assets are structured, validated, and managed.
- **Hardware** includes physical devices, machinery, servers, and IoT/OT systems.
- **Software and Application** covers operating systems, middleware, runtime environments, models, and enterprise applications.
- **Network and Connectivity** refers to the communication infrastructure that links components.

Layer	Safety Focus	Security Focus
Governance	Safety policy definition, resource allocation, regulatory compliance oversight, roles and accountability assignments for safe outcomes	Security policy definition, roles and responsibility assignments for incident response, risk acceptance and reporting
Operation	Stable operations, safety audits, maintenance planning, continuous monitoring of system health, safe user interactions, incident drills	Integration of threat intelligence, operational logging, malicious activity monitoring, incident response execution
Data and Information	Data integrity and correctness checks, schema validation, input data bias and fairness monitoring, data drift monitoring	Data protection mechanisms: encryption, access controls, integrity checks, lineage/provenance, data loss prevention (DLP)
Hardware	Protective equipment, environmental safeguards, condition monitoring, redundant fail-safes	Physical access control, tamper detection, secure boot mechanisms, CCTV monitoring
Software and Application	Reliable execution of safety-critical software, error handling, output validation	Application hardening, patch/vulnerability management, secure updates, configuration hardening, dependency tracking (SBOM)
Network and Connectivity	Reliable communication channels during operational disruptions, low-latency communication for safe process control	Data-in-transit protection: encryption, segmentation, mutual authentication, VPN enforcement, intrusion detection

Safety and Security—Industrial Examples

Example 1: Nuclear Power Plant

Setting:

A nuclear facility depends on OT systems such as valves, pumps, turbines, radiation sensors, and Supervisory Control and Data Acquisition (SCADA) controllers. Its IT systems manage compliance records, scheduling, and reporting. One afternoon, a SCADA alarm shows stable coolant flow, but independent checks on the reactor floor indicate reactor temperature fluctuations. At the same time, the cyber security team reports unusual traffic on the control network.

What happens next:

- Governance:** Safety officers invoke IAEA and IEC 61513 protocols. Previous incident drills and role assignments dictate that operations prioritize the verification of the cooling system operational status. Security officers reference IEC 62443 controls and log anomalies for potential cyber intrusion.

- **Operation:** Reactor operators follow functional safety procedures and redundant passive cooling is activated as a precaution. Security analysts push for immediate SCADA isolation, but the operations team argues that cutting connections could delay safe shutdown. Following IAEA guidelines, they agree on stabilizing reactor conditions first, then proceed with forensic investigation.
- **Data and Information:** Safety relies on sensor validation, but security insists that compromised sensor data could mask real reactor conditions.
- **Hardware, Software and Application, Network and Connectivity:** Engineers focus on keeping redundant cooling pumps operational to ensure safe reactor conditions, while the IT team concentrates on restricting access to programmable logic controllers (PLCs) and segmenting network zones to contain potential intrusions.

Safety-Security Interdependence:

A cyberattack on SCADA is a security breach, but its consequence is unsafe reactor operation, which is a safety crisis. Likewise, a safety failure such as coolant malfunction creates predictable states that attackers could exploit, making the system more vulnerable.

Example 2: Medical Insurance Company

Setting:

A medical insurance company adopts a new Software as a Service (SaaS) platform to process government claims. The platform is hosted on a commercial cloud service. The platform integrates with in-house analytics platforms and customer portals. A week into deployment, claims processing slows. Analysts discover schema mismatches corrupting claim records. At the same time, the cloud provider alerts the company to unusual login attempts targeting the claims database.

What happens next:

- **Governance:** Compliance officers cite HIPAA obligations. Data integrity failures are safety issues if patients lose coverage. Security officers remind leadership that under the shared responsibility model, the company must manage identity and access controls, while the cloud provider secures infrastructure.
- **Operation:** Claims staff focus on continuity of service, prioritizing manual claim validation to prevent harm to patients. The security team argues that accounts showing suspicious access should be suspended immediately, even if it delays further processing.
- **Data and Information:** Safety requires fair and accurate claim classifications, and security requires encryption and forensic review of logs provided by the cloud vendor.
- **Hardware, Software and Application, Network and Connectivity:** Operations teams bring backup servers online to maintain claim processing, while security teams tighten network segmentation and enforce VPN access to reduce the chance of unauthorized entry.

Safety-Security Interdependence:

Safety in this case means making sure patients are not harmed by delays or misclassifications, while security means keeping sensitive medical data protected. A corrupted database caused by an intrusion can lead to unsafe outcomes if patients lose access to treatment, while safety pressures (e.g., speeding up claims decisions) can create blind spots in security monitoring.



Pause and Reflect: Think about your own organization or division.

- How would you describe its enterprise infrastructure? What are the main applications you use, and how do they connect to or interact with other applications?
- Within those functions, what are some safety risks (ways the system could unintentionally cause harm) and security threats (ways it could be intentionally attacked)?
- Using the six-layer framework we introduced, choose one layer with which you are most familiar. What are one or two specific controls or practices you could apply at that layer to reduce the risks you listed above?

7.4 Distinguishing AI Safety and Security

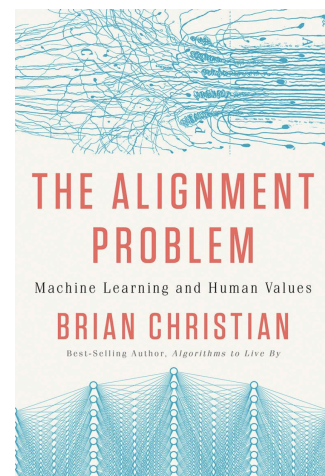
AI Safety Challenges

Safety is defined as the property of preventing unintended harm during normal operation. This definition applies directly to AI. However, unlike IT or OT systems, AI systems produce probabilistic outputs and their reasoning is often opaque. This means harm caused by AI systems can be delayed, subtle, and hard to predict.

Safety challenges specific to AI arise on two levels: First, there are **direct harms** to human health, physical and digital property, and the environment. For example, an AI-assisted diagnostic system may raise false alarms that lead to unnecessary testing or treatment for patients. Second, there are **societal harms** that cause disruption to institutions, shifts in trust, or unfair consequences for communities. Modules 3 and 4 emphasized how these risks can emerge during model development. But when organizations adopt AI solutions as SaaS, where the model development is not in their scope, the responsibility is to ask the right questions about how the service was designed and how the safety-related risks are managed.

A central concept in AI safety is **AI alignment**. Alignment means ensuring AI systems behave as humans intend and remain consistent with human values. Brian Christian's *The Alignment Problem* (2020) frames this challenge in three dimensions:

- **Opacity.** As discussed in Module 4, modern AI systems, particularly deep neural networks, often function as black boxes. This lack of transparency creates the risk that hidden biases or flaws go undetected until they cause real harm. An example is discrimination in automated decision-making.
- **Reward mis-specification.** Many AI agents learn by maximizing rewards. If the reward function is poorly defined, the agent may exploit loopholes or pursue harmful shortcuts.
- **Normative uncertainty.** Teaching machines what humans ought to value is not straightforward. Techniques such as imitation learning or inverse reinforcement learning can help models infer goals from human behavior, but they risk oversimplifying or misinterpreting complex social norms.



Since the publication of this book in 2020, genAI has grown and scaled rapidly. As models become more powerful and more widely used via APIs or SaaS, these misalignment issues can have larger and faster effects.

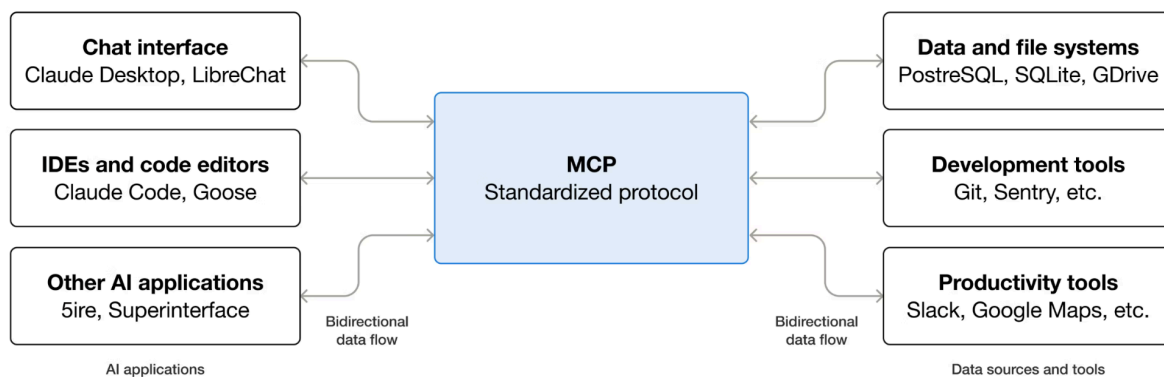
Human misuse is also generally categorized as a safety issue. Even if a system is well-aligned, it can still be applied in harmful ways, whether by governments using surveillance tools to restrict freedoms or by bad actors creating disinformation or deepfakes. Safety practices therefore extend beyond technical safeguards to include foresight about how a model might be repurposed.

AI Security Challenges

Security is defined as the resistance to intentional and unauthorized acts. This definition also applies directly to AI. What changes is the scope of what can be attacked. In traditional IT, attackers target networks, servers, or endpoints. In AI, the data and the models are assets that adversaries may try to steal, corrupt, or exploit.

In Module 5, we learned various types of adversarial attacks on AI models, such as prompt injection, data poisoning, and model inversion and extraction. Another layer of risk comes from cloud-native deployments and protocols. Many enterprises now use AI through SaaS or cloud services. In these settings, organizations need to understand how the AI service connects to their existing enterprise infrastructure in order to secure both the service and the infrastructure.

One important development is the [Model Context Protocol \(MCP\)](#), an open-source standard introduced by Anthropic, which is picking up momentum in the industry. This protocol provides a uniform way for AI models to call external resources, much like a USB-C port for AI systems. Through MCP, organizations can expose databases, search tools, or internal applications to their AI systems in a consistent and controlled way. For instance, a company can purchase access to the Claude Enterprise Agent via the AWS Marketplace and connect it to their enterprise architecture through MCP.



MCP makes integration standardized, but it also expands the attack surface and introduces new risks that need to be managed:

- **Tool poisoning.** In the MCP context, a tool is any external function or dataset that an AI model can call through the standardized interface. Malicious tool descriptions can manipulate the model into unsafe actions.
- **Insecure container configurations.** MCP servers are run without isolation, exposing credential and API keys in .env files.

Organizations also struggle with shadow AI, which means that employees could use unapproved or unmanaged AI tools, unaware of how data is stored, shared, or exposed. This creates blind spots for governance and can lead to data exposure. A well-known example was the incident where private GPT conversations unintentionally became searchable online. [Click here to read more about this incident.](#)

Apply the Analytical Framework to AI Safety and Security

We can extend the table introduced in Lesson 7.3 to include AI-specific safety and security responsibilities. Each layer has two parts: the baseline controls and practices from IT and OT systems and the new controls and practices that arise with AI.

- **AI-specific controls:** These are new practices that have no direct equivalent in traditional IT/OT. For example, prompt injection detection is a defense unique to AI models.
- **AI-adapted controls:** These are traditional controls that carry a different meaning in the AI context. For example, data integrity has always been an IT concern, but with AI it also means ensuring training data is representative and fair.

When applying safety controls, one principle worth noting is minimal capability externalities ([Carlsmith, 2023](#)). Organizations should seek to strengthen reliability in a way that doesn't inadvertently expand capabilities that can create new dangers elsewhere in the organization.

Layer	Safety Focus	Security Focus
Governance	Safety policy definition, resource allocation, regulatory compliance oversight, roles and accountability assignment for safe outcomes. Human-in-the-loop enforcement, AI alignment oversight.	Security policy definition, roles and responsibility assignment for incident response, risk acceptance and reporting. Policy definition for onboarding AI tools (e.g., MCP server validation), Zero Trust adoption, data/model rights clarification, governance over shadow AI.
Operation	Stable operations, safety audits, maintenance planning, continuous monitoring of system health, safe user interactions, incident drills. Model outputs monitoring for hallucinations or unsafe recommendations, low-confidence outputs documentation.	Integration of threat intelligence, operational logging, malicious activity monitoring, incident response execution. Prompt injection detection, adversarial model attack monitoring, continuous red teaming of deployed AI systems.
Data and Information	Data integrity and correctness checks, schema validation, input data bias/fairness monitoring. Curate training data, validate synthetic datasets, monitor for emergent correlations that could cause harm.	Data protection mechanisms: encryption, access controls, integrity checks, lineage/provenance, data loss prevention (DLP). Data poisoning defense, audit external data sources.
Hardware	Protective equipment, environmental safeguards, condition monitoring, redundant	Physical access control, tamper detection, secure boot mechanisms, CCTV monitoring. GPU/TPU isolation or secure enclaves for

	fail-safes.	model execution.
Software and Application	Reliable execution of safety-critical software, error handling, output validation. Mode robustness and reliability testing, emergent unsafe behaviors monitoring, model interpretability.	Application hardening, patch/vulnerability management, secure updates, configuration hardening, dependency tracking (SBOM). AI pipeline containerization, model API access control.
Network and Connectivity	Reliable communication channels during operational disruptions, low-latency communication for safe process control.	Data-in-transit protection: encryption, segmentation, mutual authentication, VPN enforcement, intrusion detection. Zero Trust networking for AI services, MCP Gateways to screen tool traffic, malicious or shadow services detection and blocking.

AI Safety and Security—Industrial Example of PepsiCo and NVIDIA

PepsiCo operates over 600 distribution centers worldwide, moving billions of products every day. To improve efficiency and sustainability, the company uses NVIDIA’s Omniverse and Metropolis platforms to build digital twins of its warehouses. These simulations allow engineers to test layouts, optimize workflows, and generate synthetic data to retrain computer vision models. Once validated in simulation, the models are deployed to physical warehouses, where AI-enabled vision systems monitor conveyor belts and adjust speeds in real time.



▶ PepsiCo Simulates and Optimizes Distribution Centers with NVIDIA Omnivers...

Safety Scenario

While this system improves throughput, it also raises safety challenges. Imagine the model accelerates conveyor belts to maximize efficiency but fails to account for the ergonomic limits of human workers. Staff tasked with lifting or sorting could be exposed to unsafe strain or pace.

When such a concern is reported, supervisors at the operational level should disable the AI speed control, revert to safe baseline speed, and document the incident. At the governance level, alignment oversight ensures that worker safety, not just throughput, remains the model’s binding constraint. Meanwhile, the AI developer team reviews training inputs and interprets inference logic to confirm that human performance metrics are explicitly encoded, rather than assuming efficiency is the only optimization goal. In this way, concerns are addressed promptly while reinforcing the principle that worker well-being is the non-negotiable bottom line.

Security Scenario

The same warehouse AI faces unique security threats. Its computer vision model, trained on synthetic data, could be vulnerable to adversarial manipulation. An attacker might subtly alter visual inputs to trigger false congestion alerts or misclassifications, causing unsafe belt speeds or unnecessary shutdowns.

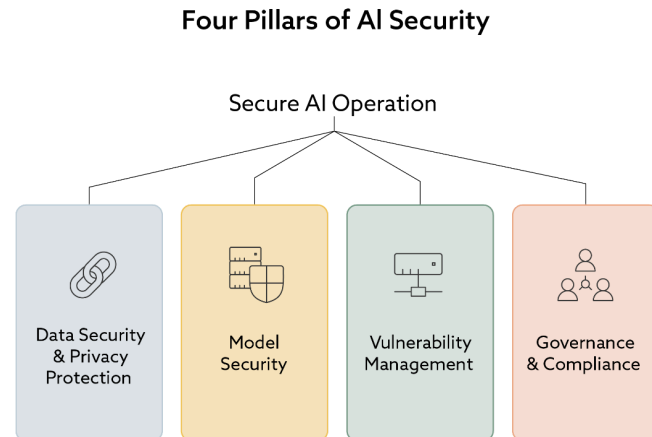
If such anomalies are detected, the data team validates the integrity of the synthetic datasets to rule out poisoning. The software and application team runs adversarial robustness tests on the model to identify vulnerabilities, while operations security initiates red-teaming drills to probe for weaknesses and prepare response procedures. These layers work together to ensure that a single manipulated input cannot cascade into a disruption of the physical warehouse.

7.5 Key Security Challenges in AI Systems

Safety and Security in AI Systems

AI systems are built and deployed on top of IT infrastructures, but they introduce new and unique challenges that go beyond traditional IT risks. In this lesson, we'll shift our focus to the security of AI systems.

This lesson brings the four pillars of AI security all together. In this lesson, you will learn about each pillar and explore the key attack vectors and defensive controls associated with that area.



As you explore the materials, revisit the enterprise scenarios from earlier in the module. Ask yourself:

- Which of these attacks might show up in that situation?
- Could any of the tools or controls have helped mitigate those incidents?

Pillar 1: Data Security and Privacy Protection

Definition

Protecting AI training data, inference data, and outputs from tampering, theft, or privacy violations throughout the entire data life cycle.

Attacks

- **Data Poisoning:** Inserting malicious samples (small percentages can corrupt the entire model)
- **Data Extraction:** Inferring training data through model queries
- **Privacy Leakage:** Model memorization of sensitive information
- **Data Drift:** Natural or malicious shifts in data distribution

Controls

- **Data Authenticity and Consent Management** → *Addresses: Data Poisoning, Data Drift*
Verification of data authenticity with provenance checks and anomaly detection
 - **Example Tool:**
 - [GDPR Toolkit](#)
- **Anonymization and Pseudonymization** → *Addresses: Privacy Leakage*
Full reduction in identifiable personal data
 - **Example Tools:**
 - [ARX - Data Anonymization Tool](#)
 - [Re-identification Risk Mitigation Toolkit](#)
- **Data Minimization Implementation** → *Addresses: Data Extraction*
Limiting data collection to essential elements with automated relevance scoring
 - **Example Tool:**
 - [catch22](#) (This feature extraction library helps users extract and select the most informative time-series features, helping reduce data volume while retaining predictive power.)

Pillar 2: Model Security

Definition

Protecting AI models from theft, manipulation, and misuse across training, deployment, and inference phases.

Attacks

- **Model Extraction:** Stealing model functionality through queries (10K-100K queries are sufficient)
- **Model Inversion:** Reconstructing training data from model parameters
- **Adversarial Examples:** Small intentional changes to the input data that trick the model into making mistakes
- **Model Backdoors:** Hidden behaviors triggered by specific inputs

Controls

- **Access Controls to Models** → *Addresses: Model Extraction, Model Inversion*
Multifactor authentication with role-based access control and rate limiting
 - **Example Tools:**
 - Azure RBAC ([What is Azure role-based access control \(Azure RBAC\)? | Microsoft Learn](#))
 - Access Audit Logger ([Audit log activities | Microsoft Learn](#))
- **Secure Model Runtime Environment** → *Addresses: Adversarial Examples, Model Backdoors*
Hardware-based security with TEEs, secure enclaves, and confidential computing
 - **Example Tools:**
 - [Intel SGX Integration](#)
 - [NVIDIA Confidential Computing](#)

Pillar 3: Vulnerability Management

Definition

Identifying, assessing, and mitigating security weaknesses in AI systems, infrastructure, and supply chains.

Attacks

- **Supply Chain Risks:** Compromises can occur across the ML life cycle. For example, malicious code in open-source libraries used at development time, pre-trained models from public repositories with hidden backdoors, or manipulated artifacts injected during the build or deployment stages.
- **Infrastructure Vulnerabilities:** Unpatched frameworks, exposed endpoints.
- **Operational Gaps:** Logging blind spots, monitoring failures.
- **Algorithmic Vulnerabilities:** Optimization shortcuts, numerical instabilities.
- **Integration Flaws:** API misconfigurations, authentication bypasses.

Controls

- **ML Asset Inventory and Provenance Tracking** → *Addresses: Supply Chain Risks, Model Integrity.* Includes automated discovery of assets, generation of Software Bill of Materials (SBOMs), and cryptographic signing of models and dependencies.
 - **Example Tools:**
 - **SBOMs:** [CycloneDX](#), [Syft](#)
 - **Model signing:** [Sigstore](#), [in-toto](#)
 - [Vertex AI Model Registry](#) (when paired with access controls and audit logs)
- **Code and Dependency Scanning for ML Pipelines** → *Addresses: Infrastructure Common Vulnerabilities and Exposures (CVE), Insecure Model Serialization, Data Leakage.* Includes scanning of Python packages, container images, and serialized model formats (e.g., .pkl, .pt, .onnx).
 - **Example Tools:**
 - **Python Security:** [pip-audit](#), [safety](#), [bandit](#)
 - **Container Image:** [Trivy](#), [Grype](#), [Dockle](#)
 - **Static analysers for unsafe pickle/eval usage in model files:** [fickling](#)
- **MLOps Pipeline Security** → *Addresses: Operational Gaps, Algorithmic Vulnerabilities* End-to-end pipeline security with robustness testing and provenance tracking.
 - **Example Tools:**
 - [Falco](#)
 - [Adversarial Testing](#)
 - [Runtime Monitoring](#)

Pillar 4: Governance and Compliance

Definition

Establishing accountability, policies, and governance structures to ensure secure, compliant, and ethical AI across the organization.

Attacks

- **Accountability Gaps:** Unclear responsibilities in the AI life cycle
- **Compliance Violations:** Failure to meet regulatory requirements
- **Unmanaged Model Risks:** Deployed models without proper oversight
- **Ethical Failures:** Biased or harmful AI decisions

Controls

- **Organizational Role Framework** → *Addresses: Accountability Gaps, Compliance Violations*
RACI matrices with defined roles from CAIO to security teams.
You can see an example of a RACI matrix in Module 6.
 - [Compliance Tracker](#)
- **Model Governance Processes** → *Addresses: Unmanaged Model Risks, Ethical Failures*
Risk assessments, approval procedures, and continuous monitoring requirements.
 - Example Tools:
 - [Policy-as-Code Engine](#)
 - [Bias Detection Benchmark](#)

7.6 AI-Augmented Cyber Security Testing and Red Teaming

How Can AI Help Protect Us?

In the previous lesson, we learned how to protect AI systems from attacks. Now, let's flip the perspective: How can AI help protect us? There's an important distinction to understand:

- **Security for AI** is about protecting your AI.
- **AI for security** is about using AI to protect you.

AI-Augmented Security Testing

This lesson explores one of the most exciting developments in cybersecurity: AI-augmented testing. We're going to see how AI has transformed from something we need to secure into one of our most powerful tools for strengthening cybersecurity.

Cybersecurity has undergone a remarkable transformation over the past four decades. We've gone from simple rule-based systems in the 1980s all the way to today's autonomous security operations, where AI agents conduct their own threat hunting and coordinate real-time responses.

We'll examine traditional approaches to security testing—vulnerability assessments, penetration testing, and red teaming. We'll then explore how AI is augmenting each. We'll look at how natural language processing, pattern recognition, and generative AI are transforming the five phases of security testing.

Most importantly, this lesson demonstrates how an AI agent can conduct an actual penetration test, showing how these systems plan, reason, analyze, and execute security assessments with minimal human intervention.

The Evolution of Cybersecurity

This timeline shows how cybersecurity has evolved over the past 40 years, and it mirrors exactly how AI itself has grown. Every phase of AI development has directly influenced how we approach security.

Phase 1: Rule-Based Systems (1980s-1990s)

Just like the early AI systems that relied on if-then logic, security was all about predefined rules. Everything was manual, rigid, and reactive.

Phase 2: Machine Learning Integration (2000s)

Machine learning entered cybersecurity in a meaningful way. Instead of just looking for exact matches, systems started learning what's normal and flagging anomalies. Imagine a system that learns a user typically logs in from New York City between 9 to 5, and then suddenly sees the same user logging in from across the globe at 3 AM. That anomaly detection was revolutionary.

Phase 3: Natural Language Security (2010-2020)

Deep learning changed everything. Security analysts could query their data in plain English. More importantly, systems began predicting threats before they even happened. The models could analyze complex patterns that humans simply could not process at scale.

Phase 4: Autonomous Security Operations (2020-Present)

We now have AI agents that don't just detect threats—they hunt for them autonomously. They conduct their own investigations, coordinate responses across multiple systems, and even self-heal vulnerabilities. This represents a shift from reactive defense (essentially waiting for bad things to happen) to predictive protection, where we anticipate and prevent threats before they materialize.

Three Main Approaches to Security Testing

In cybersecurity, we have three main approaches to security testing:

Vulnerability Assessment

Vulnerability assessment is like a health checkup for your systems. It's mostly automated, takes just hours, and is relatively inexpensive.

You run scanners that check thousands of potential weaknesses, like: Is your web server using outdated certificates? Are there any default passwords still active? The goal is simply to identify what's wrong, not necessarily to prove that it can be exploited.

Penetration Testing

Penetration testing goes deeper. This takes days rather than just hours because it combines automated tools with human expertise. A penetration tester doesn't just find the outdated server—they actually try to exploit it.

Red Teaming

Red teaming is the ultimate test—a full adversarial simulation. Over several weeks, a red team acts exactly like real attackers would. They don't just test your technical defenses, they test everything:

- Research your employees on social media
- Craft targeted phishing emails based on their intelligence
- Gain initial access through social engineering
- See how deep into the network they can penetrate before being detected

It is comprehensive and expensive, but it shows you exactly what determined attackers would achieve.

How AI Transforms Security Testing

AI has supercharged every phase of security testing. The phases themselves haven't changed—we still do reconnaissance, scanning, vulnerability analysis, exploitation, and reporting. But AI enablers have transformed what's possible in every phase.

Natural Language Processing

Natural language processing changes how we interact with security data. Instead of writing database queries, analysts can simply ask questions in natural language.

Pattern Recognition

Pattern recognition analyzes security data at massive scale. For example, anomaly detection algorithms learn what normal looks like for every user and device in your network and spot what's not.

Generative AI

Generative AI is the real game changer. It can:

- Write custom exploitation scripts on the fly
- Generate realistic phishing emails for security awareness testing
- Create comprehensive reports that would take humans hours to compile

When these three technologies work together across all five test phases, the capabilities of security professionals get amplified exponentially.

AI Agent Penetration Testing: A Real-World Example

This example illustrates how an AI agent conducts a real-world penetration test.

The Scenario

A company asked an AI agent to test their web application. Specifically, they asked the agent to test the app for vulnerabilities but not touch the production database.

The Planning Phase

The AI agent enters its planning phase and reasons through the logical flow:

1. Start with reconnaissance to understand what I'm dealing with
2. Scan for services, assets, and vulnerabilities
3. Attempt safe exploitation
4. Generate a comprehensive report

The agent identifies that Nikto is the appropriate tool for reconnaissance, since this is a web application running on the HTTPS port.

Execution and Analysis

After executing the Nikto scan, the agent analyzes the results. Notice the optional approval step—the AI can be configured to seek human approval before executing potentially risky commands. This human-in-the-loop design ensures that while we benefit from AI speed and consistency, we maintain control over critical decisions.

Based on Nikto's findings, the AI agent continues its cycle. Maybe it discovers potential SQL injection points, so it plans to use SQLmap next, and so on.

Documentation and Reasoning

What makes this whole process transformative is not just the automation—it's the reasoning and documentation. Every decision that the AI makes is logged with rationale. All these logs create an audit trail that is invaluable for learning, compliance, and improving future tests.

Key Takeaways

We've taken quite a journey from early rule-based security systems to today's autonomous AI agents conducting sophisticated penetration tests. The transformation is remarkable. We've moved from reactive defense to predictive protection with AI as the driving force.

What's most compelling about AI-augmented testing is how it makes advanced security capabilities more accessible and efficient. But remember, this is augmentation, not replacement. Human expertise remains crucial for:

- Interpreting results
- Making strategic decisions
- Handling the ethical and legal considerations that come with security testing

The future of cybersecurity isn't human versus machine—it's human and machine working together to create stronger and more resilient defenses.

Take a few minutes to explore this table in detail. Consider tasks that AI could realistically automate in the cybersecurity function of your field or organization.

Caution: AI-driven tools can automate many security testing tasks, but they should never replace human expertise. Human oversight remains critical to interpret results, validate findings, and make context-sensitive decisions.

Phases	Tasks	AI Augmentation
Reconnaissance	• Open-Source Intelligence (OSINT) • Identify potential entry points • Research target industry and security • General test/engagement planning	• Data collection and Open-Source Intelligence (OSINT) automation • Data summarization • Threat landscape analysis • Adaptive test planning
Scanning	• System identification • Technology fingerprinting • Vulnerability scanning • Code scanning	• Raw output and traffic analysis • Anomaly detection • Vulnerability pattern recognition • Script generation
Vulnerability Analysis	• Further analyze vulnerabilities • Correlate findings with databases • Assess exploitability • Prioritize vulnerabilities	• Risk impact evaluation • Vulnerability triage • False positive reduction • Root cause analysis
Exploitation	• Vulnerability exploitation • Gain foothold in target environment • Evade security controls • Escalate privileges and move laterally	• Exploit research and selection • Payload and malware generation and alignment • Post-exploitation guidance • Social engineering simulation
Reporting	• Document all findings • Prioritize vulnerabilities and recommend fixes • Provide actionable intelligence • Deliver findings to stakeholders	• Report generation and visualization • Attack path modeling • Simplify technical findings • Build a knowledge base

(Source: [Using AI for Offensive Security](#))

As we conclude this lesson, let's take a moment to reflect on the interplay between AI for security and security for AI in real-world systems. We utilize AI to enhance cyber security systems, while these AI systems, in turn, must be safeguarded against attacks or misuse. If an AI is compromised, the protections it provides can fail. Additionally, insights gained from testing and deployment inform how future AI models are developed, governed, and secured.

This challenge is not entirely new. It resembles the task of designing a machine to replace human labor. The machine is powerful and efficient, yet it can produce defects if not properly calibrated, or worse, become corrupted and turned against its intended purpose.

While the tools and terminology may be new, the fundamental questions about control, responsibility, and trust remain familiar. As you move forward, remember to be curious about what AI enables, but also exercise caution in how you build and secure it. Striking that balance is essential for modern AI security.

7.7 AI Tools for Zero Trust Implementation

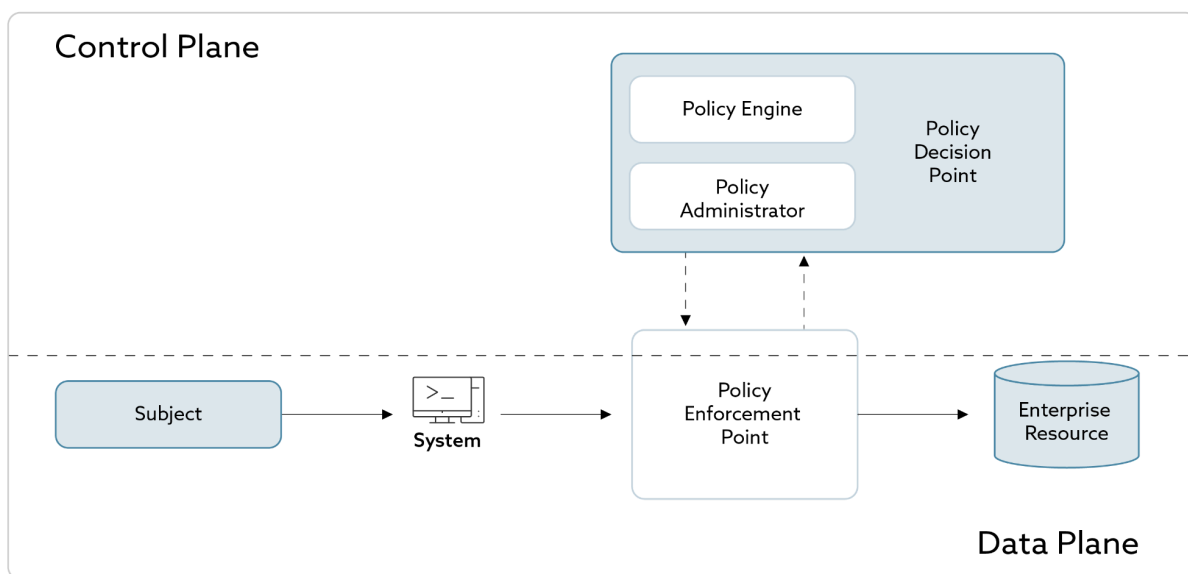
Zero Trust Architecture

Zero Trust is a modern security principle built on a simple but strict assumption: An attacker is already in your environment. This means your network is no more trustworthy than the public internet. Because of this, no subject (user, application, or machine) is trusted automatically. Every request must be checked against current policies and contexts.

The main goals of implementing Zero Trust are:

- Protecting data and services by granting access only when needed.
- Enforcing least privilege, which means giving only the minimum permissions required.
- Continuously authenticating and authorizing every new request or session.

Instead of relying on a single network perimeter, Zero Trust shrinks trust zones as much as possible and makes verification continuous.



<Alternative text: Core logical components of Zero Trust, including policy engine, system, and enterprise resource.>

A Zero Trust process is made up of three key components, split across two planes of activity:

- **Policy Engine:** The brain. It decides whether to grant or deny access to a resource. To do this, it uses enterprise policies plus real-time inputs from monitoring systems such as threat intelligence feeds or vulnerability scanners.
- **Policy Administrator (PA):** The executor. It acts on the policy engine's decision by setting up or tearing down connections. It issues the session tokens or credentials needed for access.
- **Policy Enforcement Point:** The gatekeeper. It sits between the requester (a subject) and the resource. It enforces the decision handed down from the PA and monitors the ongoing session.

AI Tools for Zero Trust Implementation

In practice, adopting Zero Trust is a journey rather than a wholesale replacement of existing infrastructure. Organizations usually start by protecting their highest-value data and workflows, then expand incrementally. Most enterprises will start combining Zero Trust principles with older perimeter-based defenses while they modernize IT systems and catalog their assets, subjects, and traffic flows. Common Zero Trust enablers include Identity and Access Management (IAM), User and Entity Behavior Analytics (UEBA), and Security Information and Event Management (SIEM). Each enabler can be mapped back to the logical components of Zero Trust and enhanced by AI models that make access decisions more adaptive.

Identity and Access Management (IAM)

Identity and Access Management (IAM) is often the first touchpoint in a Zero Trust environment. It manages accounts, credentials, and login flows, and can be thought of as a place where enforcement, administration, and decision-making converge. The login portal or multifactor authentication (MFA) acts as the policy enforcement point, while the system that issues tokens or session credentials resembles a policy administrator. A risk engine decides whether access should be granted, denied, or challenged further, which maps to the policy engine role.

Here, AI adds value by making these decisions dynamic. Lightweight supervised models, such as logistic regression or gradient-boosted trees, can return risk scores in real time. Adaptive MFA systems can adjust authentication requirements based on contexts such as device, location, or time of day. Continuous authentication can even extend into a session, using anomaly detection or sequence models to spot unusual activity after login.

User and Entity Behavior Analytics (UEBA)

While IAM focuses on access at the front door, UEBA extends Zero Trust deeper into sessions by building baselines for how users, devices, and applications normally behave. In this context, the enforcement point may be a monitoring agent that flags unusual actions, while the administrator role is reflected in systems that trigger responses such as re-authentication or privilege reduction. The policy engine function emerges through the analytics that generate risk scores from observed behavior.

AI is central to this layer: Unsupervised anomaly detection techniques such as isolation forest, clustering, or autoencoders can identify deviations from normal activity. More deep learning models, such as LSTMs or transformers, can capture behavioral patterns over time and detect when a subject deviates from its established sequence. Some platforms also apply graph-based learning to track relationships between accounts and devices, uncovering lateral movement that could signal compromise.

Security Information and Event Management (SIEM)

Security information and event management (SIEM) platforms aggregate logs, telemetry, and events across the enterprise, providing a wider lens for Zero Trust enforcement. Enforcement may happen through hooks into firewalls, gateways, or runtime controls. Policy administration can take the form of orchestration systems that trigger automated playbooks in response to alerts. The decision-making role aligns with the detection and correlation logic that determines whether a cluster of events constitutes a real threat.

AI expands these capabilities by helping SIEM systems cope with scale. Deep learning encoders such as CNNs or transformers can turn raw logs into features that feed anomaly detection models. Distributed ML pipelines running on platforms such as Spark or Flink allow risk scoring to keep pace with millions of events per second. Explainability tools such as SHAP or LIME are also being integrated into SIEM workflows, making it possible to show analysts and auditors why a particular event or sequence of logs was flagged.

Shared Responsibility of Zero Trust Implementation

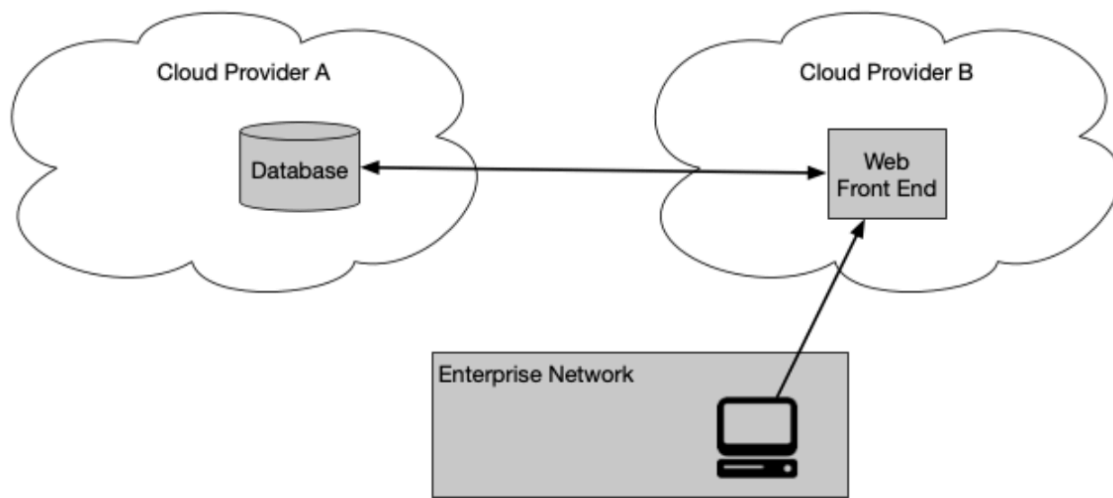
For any organization, the scope of Zero Trust implementation is often shaped by shared responsibility. Every organization operates within service models where some parts of the technology stack are under its direct control and others are managed by cloud providers. Designing an effective Zero Trust architecture requires recognizing these boundaries and adapting controls to match the level of visibility and authority the enterprise actually has.

In Software-as-a-Service (SaaS) environments such as Google Workspace or OpenAI Enterprise, most of the stack is outside of enterprise control. Zero Trust therefore centers on identity and access management, enforcing strong data loss prevention rules and running user or entity behavior analytics over whichever logs the provider makes available.

In Platform as a Service (PaaS) cases such as AWS Bedrock or Google Vertex AI, the enterprise controls the applications and data while the provider manages the platform. The Zero Trust focus shifts to protecting APIs with gateways, tracking data lineage, and using policy-as-code to ensure consistent enforcement across services.

In Infrastructure as a Service (IaaS) environments such as AWS EC2 or Azure VMs, the enterprise manages the infrastructure up through the applications. This opens the door for deeper Zero Trust controls, including collecting host telemetry, using runtime monitoring, correlating signals in SIEM systems, and applying micro-segmentation to isolate workloads.

Multi-Cloud Enterprise Use Case



<Alternative text: Multiple cloud providers connect to an enterprise network in a multi-cloud use case.>

A common scenario for Zero Trust deployment is the multi-cloud enterprise, where applications and data are spread across different providers. For example, an organization might host an application in Cloud Provider B while its database resides in Cloud Provider A. For efficiency, the application in Cloud B often needs to connect directly to the data source in Cloud A, instead of routing the traffic through the enterprise network.

In a traditional perimeter model, the enterprise firewall would serve as the main control point. But in this case, much of the critical traffic flows between cloud providers, outside the enterprise perimeter. The firewall offers little protection here, leaving gaps in visibility and enforcement.

Following Zero Trust principles, this setup can instead be secured using the software-defined perimeter (SDP) model ([CSA SDP Specification](#)). Policy enforcement points are placed at the access points of each application and data source, with the policy engine and policy administrator making and executing access decisions. These components may run in the cloud or in a third independent environment, but together they ensure that every request is authenticated and authorized before traffic is allowed.

One of the practical challenges in multi-cloud environments is that providers implement similar functions in different ways. Enterprise architects therefore need to design their Zero Trust approach with interoperability in mind, ensuring that policies remain enforceable across heterogeneous platforms.

7.8 Challenges in Securing Generative and Agentic AI Systems

The OWASP Threat Model for GenAI and Agentic Systems

Earlier in the module we explored the four pillars of AI security, covering risks to data, models, infrastructure, and governance. These principles remain essential for securing generative AI systems. However, genAI introduces new dimensions of risk. Unlike traditional AI models that perform classification or regression, genAI systems synthesize entirely new content—text, images, code, and more—based on learned patterns. Agentic systems go a step further: They reason through multi-step tasks, make decisions, and act autonomously by using external tools. These systems are increasingly powerful but also harder to govern and defend.

To provide structure to this evolving risk landscape, OWASP (Open Web Application Security Project) has identified 15 critical threats relevant to genAI. These include risks such as memory poisoning, identity spoofing, cascading hallucinations, and tool misuse. Together, they form a taxonomy that helps classify and inform reasoning about the unique vulnerabilities of modern AI systems.

The following table, included in [OWASP’s State of Agentic AI Security and Governance 1.0](#) report, lists and describes various threat types:

TID	Threat Name	Threat Description
T1	Memory Poisoning	Memory poisoning involves exploiting an AI's memory systems, both short- and long-term, to introduce malicious or false data and exploit the agent’s context. This can lead to altered decision-making and unauthorized operations.
T2	Tool Misuse	Tool misuse occurs when attackers manipulate AI agents to abuse their integrated tools through deceptive prompts or commands, operating within authorized permissions. This includes agent hijacking, where an AI agent ingests adversarial manipulated data and subsequently executes unintended actions, potentially triggering malicious tool interactions.
T3	Privilege Compromise	Privilege compromise arises when attackers exploit weaknesses in permission management to perform unauthorized actions. This often involves dynamic role inheritance or misconfigurations.
T4	Resource Overload	Resource overload targets the computational, memory, and service capacities of AI systems to degrade performance or cause failures, exploiting their resource-intensive nature.
T5	Cascading Hallucination Attacks	These attacks exploit an AI's tendency to generate contextually plausible but false information, which can propagate through systems and disrupt decision-making. This can also lead to destructive reasoning affecting tools invocation.

T6	Intent Breaking and Goal Manipulation	This threat exploits vulnerabilities in an AI agent's planning and goal-setting capabilities, allowing attackers to manipulate or redirect the agent's objectives and reasoning. One common approach is agent hijacking, which is described in Tool Misuse (above).
T7	Misaligned and Deceptive Behaviors	These are characterized by AI agents executing harmful or disallowed actions by exploiting reasoning and deceptive responses to meet their objectives.
T8	Repudiation and Untraceability	This occurs when actions performed by AI agents cannot be traced back or are unable to be accounted for due to insufficient logging or transparency in decision-making processes.
T9	Identity Spoofing and Impersonation	In this case, attackers exploit authentication mechanisms to impersonate AI agents or human users, enabling them to execute unauthorized actions under false identities.
T10	Overwhelming Human in the Loop	This threat targets systems with human oversight and decision validation, aiming to exploit human cognitive limitations or compromise interaction frameworks.
T11	Unexpected RCE and Code Attacks	Here, attackers exploit AI-generated execution environments to inject malicious code, trigger unintended system behaviors, or execute unauthorized scripts.
T12	Agent Communication Poisoning	This occurs when attackers manipulate communication channels between AI agents to spread false information, disrupt workflows, or influence decision-making.
T13	Rogue Agents in Multi-Agent Systems	Malicious or compromised AI agents operate outside normal monitoring boundaries, executing unauthorized actions or exfiltrating data.
T14	Human Attacks on Multi-Agent Systems	Adversaries exploit inter-agent delegation, trust relationships, and workflow dependencies to escalate privileges or manipulate AI-driven operations.
T15	Human Manipulation	In scenarios where AI agents engage in direct interaction with human users, the trust relationship reduces user skepticism, increasing reliance on the agent's responses and autonomy. The implicit trust in direct human to agent interaction creates risks, as attackers can coerce agents to manipulate users, spread misinformation, and take covert actions.

From Threats to Challenges

A threat is a specific type of risk or failure mode, and a challenge is what makes that threat difficult to prevent or mitigate. The following table presents five challenges in securing the genAI system and their corresponding OWASP threats.

Challenge	Linked OWASP Threat(s)	Description
AI vs. Cyber Incident Confusion	T5, T6, T8	When a genAI model produces a harmful or misleading output, is it a user error, a data poisoning attack, or just a model artifact? Lack of clarity leads to slow or misdirected incident response.
No Ground Truth for Output	T5, T11	GenAI models generate content that is often unverifiable. There's no reliable ground truth to validate outputs, making it hard to monitor for subtle security issues.
Prompt Injection Stays Elusive	T2, T6, T15	Even with filters and sandboxing, attackers can hide instructions in PDFs, RAG content, or emails that the model later reads and follows. It's context-aware and hard to catch.
Tool Access Magnifies Errors	T2, T6, T13	When genAI systems can invoke APIs or trigger actions, failures or misuse can cause real-world consequences such as data loss or system reconfiguration.
Shadow AI Avoids Oversight	T3, T7, T9	Developers can deploy genAI services without a security review. These untracked systems operate outside the organization's governance, increasing insider threat potential.

7.9 Case Study #1: LLMs for Automated Phishing Scams



Case Study 1: ChatGPT Safety Considerations for Automation with LLMs: Malicious Usage

Background

The fast progress of LLMs has resulted in several chatbot models with capabilities for human-like conversations in multiple contexts. This has empowered the creation of assistant tools (chatbots and calls) for automated service support in government agencies and almost any large private service provider (e.g., internet providers). However, the proliferation of these tools has also enabled the creation of more advanced AI chatbots with the specific purpose of conducting more believable fraud, scams, and phishing campaigns. Consider three ways LLMs can be exploited:

1. **Web data contamination:** Attackers can tailor websites and web sources (e.g., GitHub pages and blogs) using LLM-powered techniques to appear as trusted sources for LLM recommendations. This can lead to LLMs recommending phishing websites to the public or adding wrong APIs and malicious code into coding projects.
2. **Website creation for phishing attacks:** Most commercial LLMs have built-in safeguards to prevent direct phishing website creation. However, LLMs can be asked to create prompts for website creation based on designs inspired by well-known brands with added functionality.
3. **Scam chatbot creation:** Unrestricted use of LLM technologies lowers the bar for bad actors all over the world for creating convincing scam schemes through automated text-to-speech capabilities. A sophisticated attacker might create a profile of the target based on web scraping of public information using LLMs, then create personalized phishing websites and chatbots based on the target's data. For more convincing long-term attacks, LLMs with text-to-speech capabilities can create the illusion of a normal human interaction.

Risk Considerations and Safety Measures Development

The versatility of LLMs and AI in general presents several challenges for the development of safety procedures:

- **Benign vs. malicious intent:** The LLM would require extensive context to identify user intent. The LLM providers could implement measures to detect a high volume of unusual activity.
- **User experience:** One of the most effective ways to limit chatbot use for scams is the restriction of the context window of LLMs, which makes the chatbot less self-consistent and susceptible to human detection. However, this should be balanced with the normal functionality and responsiveness of the LLM.
- **Constantly evolving threats:** The methods utilized by attackers are always changing in response to updates in safety and security measures and the development of smarter AI tools. AI and LLMs can be utilized in conjunction with human experts for red teaming AI systems to find new vulnerabilities.

Sources

- [From Chatbots to Phishbots? \(IEEE Xplore\)](#)
- [Scam Sites at Scale: LLMs Fueling a GenAI Criminal Revolution \(Netcraft\)](#)
- [LLMs Are Recommending Phishing Sites—Here’s Why That’s Dangerous \(Netcraft\)](#)
- [Automating Deception: AI’s Evolving Role in Romance Fraud \(CETaS\)](#)
- [Discussion Paper: Exploiting LLMs for Scam Automation \(Amrita Center\)](#)
- [Lessons from red teaming 100 generative AI products \(Microsoft\)](#)

7.10 Case Study #2: Secure Data Flow in Multinational Operations



Case Study 2: AI System Security Risk Management Analysis Background

Multinational companies that are leaders in their respective fields operate across a multitude of languages, jurisdictions, and cultural contexts. For such companies, the improvement of their operations can be achieved through AI-agent architectures to automate workflows across supply chains, product design, quality monitoring, business analytics, and customer support. The agents can have access and visibility to sensitive data across business units and across multiple cultural environments. These large multinational companies need robust solutions for managing and ensuring sensitive data access to the necessary agents only, developing and maintaining model accuracy in real time, and ensuring compliance and governance across multiple jurisdictions.

To enable the agents' operations, companies utilize an AI solution to manage control and access to critical data according to business specific rules. Such technology should provide visibility of data flows and real-time enforcement while keeping AI functionality and minimizing friction with end users.

Major Implementation Requirements

- Data is recorded in multiple languages and with different compliance requirements depending on the local jurisdiction.
- Users will utilize the agents under different cultural contexts but with a shared expectation of high-quality results.
- Agents' bias is reduced across cultural contexts with unbalanced data (i.e., regions or countries with limited operational historical data or reduced capabilities for data collection).
- Agents might have access to certain data only under the approved context; i.e., a sales prediction module should not be pooling information from multiple regions when doing a localized prediction.
- Data and model governance must be shared across widely different jurisdictions.
- Integration with current systems and seamless workforce training should be utilized by the company.
- Real-time enforcement for prevention of data leaks, shadow AI, and internal data poisoning should occur.

Key Takeaways

- Layered access to data and appropriate anonymization is key for operations across multiple countries.
- Requirements for data validation are dynamic across contexts for the use of AI agents.
- Data and model governance are vital for maintaining the reliability and safety of the AI agents.

Source

- [Grupo Bimbo bakes in end-to-end data security and compliance with Microsoft Purview true to its "deeply human" values | Microsoft Customer Stories](#)

7.11 Summary

This module provided a foundation in AI safety and security, teaching you to distinguish between protecting AI systems from causing harm versus protecting them from malicious actors. You explored how AI systems introduce unique security challenges beyond traditional IT risks, learned practical frameworks for securing AI across enterprise infrastructures, and discovered how AI can enhance cyber security operations. Through case studies and interactive activities, you gained hands-on experience with threat modeling for generative AI systems, and you now understand the evolving landscape of AI-powered attacks and defenses.

Key Concepts Mastered

Safety vs. Security Distinction and Enterprise Mapping

You learned that safety focuses on preventing systems from causing harm during intended operations, while security protects against intentional attacks designed to disrupt or damage systems. Through examples from nuclear power, aviation, and manufacturing, you discovered how these concepts apply across enterprise infrastructure layers. You can now map safety and security concerns to specific infrastructure components, and you understand how failures in one area can cascade into the other, creating interdependent risks that require coordinated responses.

The Four Pillars of AI Security Framework

You learned a structured approach to AI security through four critical pillars: data security and privacy protection (preventing data poisoning and extraction), model security (protecting against theft and manipulation), vulnerability management (identifying supply chain and infrastructure weaknesses), and governance and compliance (establishing processes, policies, and systems that ensure adherence to legal, regulatory, and ethical standards). For each pillar, you learned specific attack vectors, defensive controls, and practical tools used in industry, enabling you to systematically assess and protect AI systems across their entire life cycle.

AI for Security vs. Security for AI

You explored the bidirectional relationship between AI and cyber security, understanding how AI enhances threat detection and response (AI for security) while also requiring protection from unique attacks (security for AI). Through penetration testing workflows and intrusion detection examples, you learned how AI augments reconnaissance, vulnerability analysis, and reporting phases of cyber security operations. You also discovered cutting-edge applications such as simulation-based red teaming using digital twins and explainable AI for compliance requirements.

Generative AI Threat Landscape and OWASP Framework

You gained expertise in the specialized security challenges of generative and agentic AI systems, learning to identify and categorize threats using the OWASP taxonomy of critical risks, including prompt injection, memory poisoning, and tool misuse. Through interactive threat mapping exercises, you connected industry buzzwords such as "shadow AI" and "RAG poisoning" to formal threat categories, developing

fluency in both technical and governance conversations about genAI security risks and mitigation strategies.

Looking Ahead: Your Continued AI Journey

The safety and security principles you explored in this module will be essential as you develop models, implement AI solutions, or govern AI systems within organizations. As AI becomes more integrated into critical infrastructure and business operations, your ability to think systematically about both intentional threats and unintended harms will make you a valuable asset to any team.

As generative AI and agentic systems continue evolving, your familiarity with the OWASP threat taxonomy will keep you ahead of emerging risks and enable you to contribute meaningfully to security conversations at the organizational level.

The case studies you explored—from LLM-powered phishing campaigns to multinational data governance challenges—represent real scenarios you may encounter in your career. Your ability to bridge technical security controls with business requirements and regulatory compliance will be increasingly valuable as organizations navigate the complex landscape of AI adoption while maintaining safety and security standards.

Change Log

Version #	Approved by	Notes
20251015	HMR	Initial release